PART A — FUNDAMENTALS

1. What is cryptography?
It is a practice of protecting information using mathematical techniques to prevent unauthorized access and ensure data using integrity, confidentiality, and authenticity.

2. What is A04:2025 Cryptographic Failures?
Cryptographic Failures is an OWASP security category when a application failed to protect sensitive data due to weak, incorrectly or missing cryptographic controls.

3. What is sensitive data? Give four examples.
Sensitive data is information that needs protection from unauthorized access and risks.

- Passwords
- Credentials
- Medical Records
- Personal Identification Information

4. Explain data at rest.
It refers to the data stored on device or system, such as hard drives or files, database records even stored backups.

5. Explain data in transit.
It refers to the data being transferred between system or devices through network.

6. What is encryption?
Encryption is a process of converting plain text to ciphertext using cryptographic key to prevent unauthorized access.

7. What is hashing?
It is a process of converting data into a fixed-length value called hash using a hashing algorithm. It is usually a one-way process.

8. Explain the difference between encryption and hashing.

- Encryption: It is reversible, using correct decryption key.
- Encryption: Protects data's confidentiality.
- Hashing: Irreversible.
- Hashing: Password storage and Data integrity verification.

9. Why is Base64 not encryption?
It is a encoding technique. It only changes representation of data and can be easily decoded without a cryptographic key, so it doesn't provide security.

10. Why should passwords never be stored in plaintext?
If passwords are stored in plaintext attackers can gain direct access to database and been able to find them. Instead storing it as secure password-hashing with unique salts to protect user's accounts.

PART B — PASSWORD & KEY SECURITY

11. What is password hashing?
It is a process of converting a password into fixed-length hash value using a secure hashing algorithm.

12. What is a salt?
It is a unique random value added to a password before hashing to make password attacks.

13. Why are unique salts useful?
Unique salts are useful cause it ensures identical passwords produce different hash values making it hard for attackers to identify users with same password hash tables.

14. What is a cryptographic key?
It is a value used by cryptographic algorithm to protect data, encrypt or decrypt.

15. What is key management?
It is a process of securely creating, storing, using, rotating, distributing and deleting cryptographic keys.

16. Why is hardcoding a production encryption key in source code risky?
If the source code is exposed by unauthorized people, attackers may obtain the encryption key and use it to decrypt sensitive data. Keys should instead be stored securely using a secret manager or management system.

PART C — CRYPTOGRAPHY

17. Explain symmetric encryption.
It is a type of encryption that uses the same key to encrypt or decrypt data. The key must be kept secure and shared with authorized people.

18. Explain asymmetric cryptography.
It uses two keys known as public and private key. The public key can be shared while private key remains secret.

19. What is TLS?
TLS also known as Transport Layer Security. It is a cryptographic protocol that protects data transmitted between system by providing encryption, authentication or data integrity.

20. Why is HTTPS important when transmitting sensitive information?
HTTPS use TLS encrypt communication between web server and browser. It helps prevent attacker from intercepting information such as password, payment details and personal data.

PART D — PRACTICAL ANALYSIS

Analyze this fictional application:

Login Transport: HTTPS

Passwords: Stored as Plaintext

Encryption Key: Stored in Public Source Code

Session Token: 10001, 10002, 10003...

Certificate Validation: Enabled

Answer:

1. Identify the positive security controls.
   - HTTPS protect communication between web server and browser using TLS encryption.
   - Certificate Validation Enabled: Helps verify server's identity prevent connections to servers with invalid certificate.

2. Identify every cryptographic problem.
   - Passwords stored as Plaintext
   - Encryption key stored in public source code.
   - Sequential access tokens

3. Which OWASP Top 10:2025 category applies: A:04:25-Cryptographic Failures.

4. Why is plaintext password storage dangerous?
If an attacker gains access to database they can directly read user's passwords. This can help attacker stole credentials and use accounts.

5. Why is the hardcoded key a problem?
If the public source code is accessed by attackers, they can obtain the encryption key and potentially decrypt sensitive information. Encryption keys should be stored securely outside the source code.

6. Why are sequential security tokens weak?
Sequential tokens are predictable and can be guessed by attackers. This may allow attackers to hijack user sessions and gain unauthorized access to accounts.

7. Give three defensive recommendations.
   - Secure Password storage.
   - Secure key management.
   - Secure session tokens.